

Encuesta Integral TRIKE-TRIKE (Threat, Risk, Impact, Knowledge, Evaluation)

Diagnóstico de Madurez y Métricas de Ciberseguridad a Nivel Organizativo

Versión 1.0 – Orientada a organizaciones españolas sujetas (o potencialmente sujetas) a NIS2, Ley 43/2022 y normativa sectorial conexas.

Este cuestionario no juzga: solo sostiene un espejo. Lo que refleje ya es asunto suyo.

0. Información general de la organización

P0.1 – Tipo de organización

Seleccione la opción que mejor describa su entidad.

- Administración pública estatal
- Administración autonómica
- Administración local
- Empresa privada – gran empresa (>250 empleados)
- Empresa privada – pyme (10–249 empleados)
- Microempresa / autónomo
- Operador de servicios esenciales / entidad importante (NIS2)
- Otro (especificar: _____)

P0.2 – Sector principal de actividad

- Sanidad
- Energía
- Transporte
- Servicios digitales / TIC
- Finanzas / seguros
- Industria / manufactura
- Educación / investigación
- Administración pública
- Otro (especificar: _____)

P0.3 – Alcance geográfico principal de operaciones

- Local / provincial
- Autonómico
- Nacional
- UE
- Global

P0.4 – Tamaño aproximado de plantilla

- < 50
- 50–249
- 250–999
- ≥ 1.000

P0.5 – Contacto responsable de la respuesta

- Nombre: _____
- Rol (CISO, CIO, DPO, Responsable de Riesgos, etc.): _____
- Correo electrónico: _____
- Acepto ser contactado para aclaraciones o benchmarking anónimo:
- Sí
- No

1. Dimensión “T” – Threat (Amenaza)

1.1 Identificación y taxonomía de amenazas

P1.1 – ¿Dispone la organización de un catálogo formal de amenazas?

- Sí, documentado y aprobado por la dirección
- Sí, documentado pero sin aprobación formal
- Parcial, solo para ciertos sistemas o proyectos
- No, se trabaja de forma ad hoc
- No, pero estamos en proceso de crearlo

P1.2 – ¿Con qué frecuencia se actualiza el catálogo de amenazas?

- Al menos una vez al trimestre
- Al menos una vez al año
- Solo tras incidentes significativos
- Cuando hay cambios tecnológicos relevantes
- No existe un ciclo definido de actualización

P1.3 – ¿Qué fuentes utiliza para identificar nuevas amenazas? (selección múltiple)

- Informes de CERT nacionales (INCIBE, CCN-CERT)
- Informes de ENISA y organismos de la UE
- Informes de proveedores (fabricantes de seguridad, cloud, etc.)
- Informes de asociaciones profesionales (ISACA, (ISC)², etc.)
- Inteligencia de amenazas propia o de terceros
- Medios generalistas / noticias
- No utilizamos fuentes sistemáticas

1.2 Modelado de amenazas (incluyendo TRIKE)

P1.4 – ¿Realiza la organización modelado de amenazas en sus proyectos/sistemas clave?

- Sí, sistemáticamente en todos los proyectos relevantes
- Sí, pero solo en proyectos considerados críticos
- Ocasionalmente, según la percepción del riesgo
- Muy raramente / casi nunca
- Nunca

P1.5 – ¿Qué metodologías de modelado de amenazas utiliza? (selección múltiple)

- TRIKE
- STRIDE u otras metodologías de Microsoft
- OCTAVE
- LINDDUN / centradas en privacidad
- Marco propio interno
- Marco definido por terceros (proveedor, integrador, etc.)
- Ninguna metodología formal

P1.6 – En los casos en que aplica TRIKE (o similar), ¿qué nivel de formalización existe?

- Diagramas de flujo de datos (DFD) completos, con actores, activos y flujos identificados
- Inventario de amenazas por flujo de datos
- Valoración cuantitativa de probabilidad e impacto
- Definición explícita de riesgos aceptados, mitigados, transferidos
- Solo se realiza un análisis cualitativo de “qué podría ir mal”
- No aplicamos TRIKE ni equivalente

1.3 Métricas de amenaza

P1.7 – ¿Dispone de métricas numéricas sobre amenazas a nivel organización (p.ej. incidentes/100 usuarios, incidentes por sector, etc.)?

- Sí, de forma sistemática y con series históricas ≥ 3 años
- Sí, pero solo para algunos indicadores clave
- Tenemos datos, pero no están consolidados como métricas
- No, solo recuentos puntuales de incidentes
- No medimos este aspecto

P1.8 – ¿Realiza comparativas (“benchmarking”) de su exposición a amenazas frente a otras organizaciones o frente a datos sectoriales nacionales/internacionales?

- Sí, utilizando fuentes europeas (ENISA, NIS2, etc.)
- Sí, utilizando fuentes globales (informes de fabricantes, consultoras, etc.)
- Sí, pero solo de forma informal o esporádica
- No, pero nos gustaría empezar a hacerlo
- No, y no es una prioridad actualmente

2. Dimensión “R” – Risk (Riesgo)

2.1 Marco de gestión del riesgo

P2.1 – ¿Cuenta la organización con un marco formal de gestión de riesgos de ciberseguridad?

- Sí, integrado en el marco general de riesgos corporativos
- Sí, específico para ciberseguridad
- Parcial, con prácticas dispersas según áreas
- No, se gestiona de forma reactiva
- No, y no se contempla por el momento

P2.2 – ¿Qué marcos de referencia utiliza para la gestión del riesgo? (selección múltiple)

- ISO 27005
- NIST SP 800-30 / 800-37
- FAIR (Factor Analysis of Information Risk)
- Metodologías nacionales (CCN-STIC, ENS, etc.)
- Marcos reguladores sectoriales (financiero, sanitario, etc.)
- Marco propio
- Ninguno claramente definido

2.2 Cuantificación del riesgo

P2.3 – ¿Cómo cuantifica el riesgo en su organización?

- Cuantitativamente, en términos económicos (pérdida esperada anual u otras métricas monetarias)
- Semi-cuantitativamente (escalas de probabilidad e impacto con valores numéricos)
- Cualitativamente (bajo/medio/alto, etc.)
- De manera informal, sin criterios definidos
- No se cuantifica el riesgo de forma explícita

P2.4 – ¿Se vinculan los resultados del análisis de riesgos a decisiones presupuestarias y de inversión en seguridad?

- Sí, de forma sistemática y documentada
- Sí, pero solo para proyectos significativos
- Ocasionalmente, según contexto
- Rara vez
- No, el presupuesto se define por otros criterios

2.3 Ciberseguro y transferencia de riesgo

P2.5 – ¿Dispone la organización de póliza(s) de ciberseguro?

- Sí, póliza específica de ciberseguridad
- Sí, cobertura parcial dentro de otras pólizas
- No, pero se está evaluando activamente
- No, y no se contempla a corto plazo
- No lo sé

P2.6 – ¿Utiliza métricas de riesgo (internas o externas) para negociar o dimensionar su ciberseguro?

- Sí, disponemos de indicadores sólidos y los compartimos con aseguradoras
- Sí, de forma limitada, con algunos indicadores básicos
- No, dependemos de las estimaciones del proveedor de seguros
- No aplicable (no tenemos ciberseguro)

3. Dimensión “I” – Impact (Impacto)

3.1 Medición de impacto económico y operacional

P3.1 – ¿Registra el impacto económico de los incidentes de ciberseguridad?

- Sí, con estimaciones detalladas y validadas por Finanzas
- Sí, con estimaciones aproximadas
- De manera informal (p.ej. “fue importante / menor”)
- No se mide el impacto económico
- No se han producido incidentes relevantes (que sepamos)

P3.2 – ¿Mide la duración de las interrupciones de servicios esenciales causadas por incidentes?

- Sí, de forma sistemática para todos los servicios críticos
- Sí, para algunos servicios
- Solo cuando el incidente es grave
- No se mide
- No aplica (según la organización)

P3.3 – ¿Tiene definida una clasificación de niveles de impacto (p.ej. menor, significativo, crítico) con criterios objetivos?

- Sí, documentada y aplicada
- Sí, documentada pero aplicada de forma irregular
- Existe de facto, pero no documentada
- No, se decide caso por caso
- No, y no se considera necesario

3.2 Impacto reputacional, regulatorio y sistémico

P3.4 – ¿Evalúa sistemáticamente el impacto reputacional de los incidentes (p.ej. cobertura mediática, redes sociales, percepción de clientes)?

- Sí, con métricas definidas y seguimiento periódico
- Sí, pero solo en incidentes de alto perfil
- De forma informal
- No se evalúa
- No aplica

P3.5 – ¿Incluye el riesgo de sanciones regulatorias (NIS2, RGPD, sectoriales) como parte del impacto en sus análisis de riesgo?

- Sí, con estimaciones económicas explícitas
- Sí, de forma cualitativa
- No, se contempla tangencialmente
- No, no se considera en la práctica
- No aplica

P3.6 – ¿Evalúa el impacto sistémico potencial (efectos en cadena de suministro, terceros, ecosistemas) en sus modelos de riesgo?

- Sí, con análisis explícitos de interdependencias
- Sí, pero solo para algunos proveedores o socios críticos
- De forma ad hoc cuando surge un caso
- No se evalúa de forma estructurada
- No aplica

4. Dimensión “K” – Knowledge (Conocimiento)

4.1 Inteligencia de amenazas y lecciones aprendidas

P4.1 – ¿Cuenta la organización con un programa de inteligencia de amenazas (propio o de terceros)?

- Sí, estructurado y con objetivos claros
- Sí, pero de forma limitada
- No formalizado, pero se reciben algunos feeds o boletines
- No, no contamos con inteligencia de amenazas

P4.2 – ¿Cómo se evalúa la eficacia de la inteligencia de amenazas?

- Con métricas definidas (tiempo desde la detección hasta la mitigación, incidentes prevenidos, etc.)
- Con revisiones periódicas cualitativas
- De forma informal (“nos parece útil / no útil”)
- No se evalúa

P4.3 – ¿Documentan y reutilizan “lecciones aprendidas” tras incidentes o simulacros?

- Sí, con informes post-mortem estructurados (post-incident reviews)
- Sí, pero con documentación irregular
- Solo para incidentes graves
- No, se aprende “sobre la marcha”
- No se han realizado ejercicios ni han ocurrido incidentes relevantes

4.2 Capacidades, talento y cultura

P4.4 – ¿Dispone la organización de un plan de formación en ciberseguridad para el conjunto de la plantilla?

- Sí, plan anual formal con contenidos y métricas
- Sí, con acciones puntuales
- Solo para perfiles técnicos
- Solo para directivos
- No existe un plan específico

P4.5 – ¿Cómo describiría la cultura organizativa respecto a la ciberseguridad?

- Altamente integrada en la toma de decisiones y la estrategia
- Considerada importante, pero subordinada a otros objetivos
- Reactiva: se habla de ella cuando hay problemas
- Considerada principalmente un coste o un requisito legal
- Culturalmente invisible

5. Dimensión “E” – Evaluation (Evaluación)

5.1 Evaluación de controles y del modelo

P5.1 – ¿Evalúa periódicamente la eficacia de sus controles de seguridad?

- Sí, con métricas de desempeño y pruebas planificadas
- Sí, pero de forma parcial o irregular
- Solo tras incidentes o auditorías
- No existe una evaluación sistemática

P5.2 – ¿Integra la revisión del modelo de amenazas en ciclos de mejora continua (p.ej. al menos anual o tras cambios relevantes)?

- Sí, según un ciclo formal (p.ej. PDCA, roadmap de seguridad)
- Sí, de forma más informal
- Solo tras incidentes graves
- No, el modelo se creó en su día y apenas se revisa
- No se dispone de un modelo de amenazas

P5.3 – ¿Se utilizan los resultados de la evaluación para ajustar prioridades y recursos de seguridad?

- Sí, de manera explícita y documentada
- Sí, pero sin trazabilidad clara
- Ocasionalmente
- No, se consideran como “recomendaciones” sin impacto real

5.2 Cumplimiento normativo y auditorías

P5.4 – ¿Está su organización sujeta (o previsiblemente sujeta) a NIS2 o normativa equivalente?

- Sí, ya estamos formalmente incluidos
- Sí, previsiblemente lo estaremos
- No, pero seguimos la normativa como referencia de buenas prácticas
- No aplica
- No lo sabemos con certeza

P5.5 – ¿Qué nivel de alineamiento considera que tiene su organización con los requisitos de gestión de riesgos y gobernanza de NIS2 / normativa nacional?

- Alto: cumplimos la mayoría de requisitos con evidencia documental
- Medio: cumplimos parcialmente, con lagunas claras
- Bajo: estamos en fase inicial de alineamiento
- Muy bajo: apenas se ha empezado a trabajar en ello
- No aplica / no sabemos

P5.6 – ¿Con qué frecuencia se somete la organización a auditorías internas o externas de ciberseguridad?

- Al menos anuales (internas y/o externas)
- Cada 2–3 años
- Solo cuando lo exige un regulador o cliente
- Muy raramente
- Nunca

6. Métricas, indicadores y ROI (visión TRIKE)

6.1 Indicadores clave de gestión (IGM) y madurez

P6.1 – ¿Dispone de un cuadro de mando (dashboard) con indicadores de ciberseguridad revisado por la alta dirección?

- Sí, en reuniones periódicas (mensuales o trimestrales)
- Sí, pero de forma irregular
- Solo a petición de la dirección
- No, la dirección no revisa indicadores formales
- No se dispone de indicadores consolidados

P6.2 – ¿Qué tipo de indicadores se incluyen principalmente? (selección múltiple)

- Indicadores de amenazas (intentos de ataque, tipos, etc.)
- Indicadores de incidentes y su impacto
- Indicadores de cumplimiento normativo
- Indicadores de formación y concienciación
- Indicadores financieros (costes, ROI, etc.)
- Otros (especificar: _____)

P6.3 – ¿Utiliza algún modelo de madurez para valorar su situación global (p.ej. CMMI, propio, ENS, etc.)?

- Sí, modelo formal con niveles definidos
- Sí, modelo propio ad hoc
- Informalmente (“sabemos más o menos dónde estamos”)
- No se utiliza ningún modelo de madurez

6.2 Retorno de la inversión (ROI) en ciberseguridad

P6.4 – ¿Realiza cálculos explícitos de ROI o de coste/beneficio de inversiones en ciberseguridad?

- Sí, de forma sistemática
- Sí, pero solo para proyectos grandes
- Ocasionalmente
- No, aunque se reconoce la necesidad
- No, y no está en la agenda

P6.5 – ¿Cómo se percibe internamente el retorno de la inversión en ciberseguridad?

- Como habilitador estratégico (confianza, nuevas líneas de negocio, etc.)
- Como mecanismo de reducción de pérdidas y sanciones
- Como un coste inevitable para cumplir normativas
- Como un coste prescindible salvo obligación
- No hay una narrativa interna clara sobre el ROI

7. Cierre y perspectiva

P7.1 – ¿Cuál considera que es su principal obstáculo para mejorar en Threat, Risk, Impact, Knowledge y Evaluation?

- Falta de presupuesto
- Falta de talento especializado
- Falta de apoyo de la dirección
- Complejidad regulatoria
- Fragmentación tecnológica / heredada
- Cultura organizativa
- Otro (especificar: _____)

P7.2 – Si tuviera que elegir una sola dimensión TRIKE para mejorar de forma prioritaria en los próximos 12 meses, ¿cuál sería?

- Threat
- Risk
- Impact
- Knowledge
- Evaluation
- Ninguna, “ya somos perfectos” (si marca esta, le llamaremos para que nos lo cuente)

P7.3 – Comentarios adicionales

Espacio libre para desahogarse, proponer, o dejar constancia de que “se hizo lo que se pudo”: